

S.A.A.RE. PROTOCOL

RUNTIME AI GOVERNANCE & INFRASTRUCTURE ENGINEERING

SAARE AI Governance Framework V4

Especificación Técnica Oficial y Estándar de Gobierno Operativo en Tiempo de Ejecución para Sistemas de Inteligencia Artificial Generativa y Modelos Masivos de Lenguaje (LLM) en Entornos Corporativos Regulados.

ISO/IEC 42001 ALIGNED

EU AI ACT COMPLIANT

LAYER 7 PEP

ZERO-DISK ARCHITECTURE

Document ID: SAARE-FRAMEWORK-V4-SPEC-2026

Master SHA-256: fb3fe6a18a0e05b995922579562f04d4d6badb215ea91d103b5d5276d1b9dfbd

Clasificación: Especificación Técnica Homologada

Publicación: Febrero 2026

Estado: V4.0.0 PROD-STABLE

Dominio: <https://saare.es/>

1. Resumen Ejecutivo y Alcance Estratégico	Pág. 2
2. Principios Fundamentales del Framework V4	Pág. 2
3. Arquitectura Desacoplada de 3 Planos (Control, Governance & Data)	Pág. 3
4. Interceptación Ex-Ante en Capa 7 (Policy Enforcement Point - PEP)	Pág. 4
5. Motor de Sanitización y Anonymization de Datos (PII/PHI)	Pág. 4
6. Gestión Volátil de Memoria y Purga Irreversible (Zero-Disk Enforcement)	Pág. 5
7. Criptografía, Licenciamiento Ed25519 y Firma Inmutable SoA	Pág. 5
8. Matriz de Alineamiento Regulatorio (ISO 42001, EU AI Act, DORA, RGPD)	Pág. 6
9. Guía de Despliegue, Validación de Rendimiento y Benchmark SLA	Pág. 6

1. Resumen Ejecutivo y Alcance Estratégico

El **SAARE AI Governance Framework V4** nace como respuesta técnica a la convergencia entre la adopción masiva de modelos de Inteligencia Artificial Generativa (LLMs, SLMs y agentes autónomos) y la entrada en vigor de marcos normativos restrictivos internacionales, tales como el **EU AI Act**, la norma **ISO/IEC 42001:2023** y el reglamento **DORA**[cite: 2].

A diferencia de los enfoques tradicionales basados en auditorías retrospectivas o análisis de logs, S.A.A.R.E. establece un **modelo de gobierno operativo en tiempo de ejecución (Runtime Governance)**[cite: 2]. El marco garantiza que cada interacción (prompts, payloads de API, documentos) sea evaluada, filtrada y sanitizada *ex-ante* antes de que los datos atraviesen el perímetro corporativo[cite: 2].

OBJETIVO ESTRATÉGICO PRINCIPAL

Proveer una infraestructura técnica determinista que elimine el riesgo de Fuga de Propiedad Intelectual (IP), filtración de Datos Personales (PII/PHI) y ejecuciones no autorizadas (Shadow AI), garantizando un tiempo de procesamiento ultrabajo (< 1.2 ms) y generando evidencia criptográfica inmutable[cite: 2].

1.1 Desafíos del Paradigma de IA Unprotected

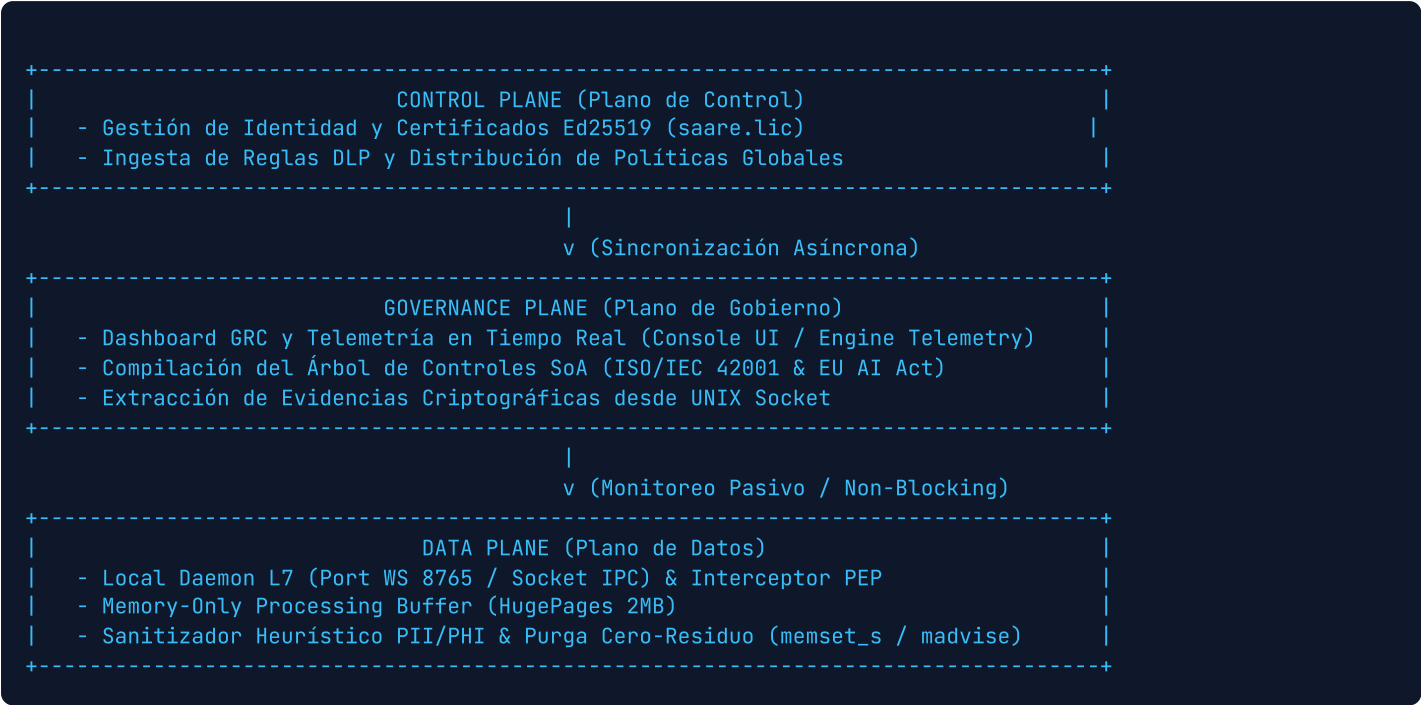
- **Fuga de PII/PHI (RGPD Art. 83):** Envío inadvertido de datos personales o financieros hacia APIs públicas de proveedores LLM en la nube[cite: 2].
- **Alucinaciones e Indeterminación:** Inexistencia de cortafuegos semánticos que validen las respuestas antes de impactar en negocio[cite: 2].
- **Persistencia Indeseada:** Almacenamiento en disco de conversaciones con secretos comerciales[cite: 2].
- **Ausencia de Evidencia Forense:** Incapacidad para demostrar trazabilidad de políticas ante auditores[cite: 2].

2. Principios Fundamentales del Framework V4

#	PRINCIPIO METODOLÓGICO	ESPECIFICACIÓN TÉCNICA	OBJETIVO SLA
P1	Memory-Only Processing	Procesamiento exclusivo en memoria volátil sin escritura secundaria en disco o SWAP[cite: 2].	0.00% Residuo en Disco[cite: 2]
P2	Policy Enforcement Ex-Ante (PEP L7)	Interceptación y evaluación semántica síncrona en Capa 7 previo a la transmisión[cite: 2].	100% Cobertura In-Flight[cite: 2]
P3	Cryptographic Evidence Generation	Emisión síncrona de firmas HMAC-SHA256 vinculadas al árbol de controles ISO 42001[cite: 2].	Sello HMAC Determinista[cite: 2]
P4	Vendor-Agnostic Integration	Arquitectura compatible de forma transparente con proveedores LLM en la nube, APIs públicas o modelos On-Premise[cite: 2].	Interoperabilidad L7 Universal[cite: 2]
P5	Deterministic Low-Latency	Ejecución optimizada en C/C++ y Rust para minimizar el impacto en producción[cite: 2].	Latencia ~1.16 ms[cite: 2]

3. Arquitectura Desacoplada de 3 Planos

El Framework V4 divide las responsabilidades del sistema en tres planos de ingeniería aislados para evitar cuellos de botella en el tráfico transaccional[cite: 2]:



3.1 Control Plane

Gestiona el licenciamiento mediante firmas **Ed25519**, permitiendo validación en entornos *air-gapped* sin conexión continua a internet[cite: 2].

3.2 Governance Plane

Proporciona las interfaces de auditoría (Console UI / Telemetry Dashboard) para la extracción de la Declaración de Aplicabilidad (SoA) sin afectar el rendimiento transaccional[cite: 2].

3.3 Data Plane

Motor de ejecución local que escucha en sockets IPC (`/var/run/saare_core.sock`) para inspección semántica síncrona en tiempo real[cite: 2].

4. Interceptación Ex-Ante en Capa 7 (PEP)

Actúa como un **Layer 7 Policy Enforcement Point (PEP)**, analizando la estructura JSON/HTTP y el contenido semántico de las peticiones[cite: 2]:

1. **Captura:** Redirección de la llamada API hacia el socket local del demonio[cite: 2].
2. **Parsing:** Extracción de campos clave (``prompt``, ``messages``, ``documents``) en memoria volátil[cite: 2].
3. **Evaluación DLP:** Ejecución paralela de reglas (``AUDIT``, ``REDACT``, ``BLOCK``)[cite: 2].
4. **Acción:** Transmisión directa (``ALLOW``), anonimización sintética (``REDACT``) o bloqueo 403 (``BLOCK``)[cite: 2].
5. **Sello de Evidencia:** Generación del hash HMAC-SHA256 del evento[cite: 2].

5. Motor de Sanitización de Datos (PII/PHI)

CATEGORÍA	PATRÓN / ENTIDAD DETECTADA	ACCIÓN	TOKEN DE SUSTITUCIÓN SINTÉTICO
Identificación	DNI, NIE, Pasaportes, Licencias de Conducir[cite: 2].	REDACT[cite: 2]	[REDACTED_NATIONAL_ID][cite: 2]
Financieros	Tarjetas de Crédito (PAN/Luhn), Cuentas IBAN[cite: 2].	BLOCK / REDACT[cite: 2]	[REDACTED_FINANCIAL_IBAN][cite: 2]
Médicos (PHI)	Nº Afiliación Seguridad Social, Códigos CIE-10[cite: 2].	REDACT[cite: 2]	[REDACTED_HEALTH_RECORD][cite: 2]
Credenciales & IP	API Keys, Claves Privadas RSA/PEM, IPs Internas[cite: 2].	CRITICAL BLOCK[cite: 2]	[BLOCKED_SECRET_KEY][cite: 2]

6. Gestión Volátil y Purga Irreversible (Zero-Disk)

Asignación de bloques de memoria estancos mediante **HugePages** de 2MB administrados directamente por el kernel[cite: 2]:

```
// Secuencia C/POSIX para purga segura de buffers post-inferencia
#include <sys/mman.h>
#include <string.h>

void purge_sensitive_buffer(void* buffer_address, size_t buffer_size) {
    // 1. Sobrescritura irreversible con ceros binarios
    memset_s(buffer_address, buffer_size, 0, buffer_size);

    // 2. Notificación al Kernel para destrucción de la tabla de páginas
    madvise(buffer_address, buffer_size, MADV_DONTNEED);

    // 3. Desasignación del bloque virtual
    munmap(buffer_address, buffer_size);
}
```

GARANTÍA ZERO-DISK

Tras la ejecución de `purge_sensitive_buffer`, los transistores RAM retornan a estado neutro (0x00). Es matemáticamente imposible recuperar información mediante volcados de memoria o análisis forense[cite: 2].

7. Licenciamiento Criptográfico Ed25519

Estructura del token `.lic`` firmado digitalmente[cite: 2]:

```
{
  "payload": {
    "client_id": "ENTIDAD_CLIENTE_SL",
    "email": "auditoria@entidad-cliente.com",
    "tier": "SAARE_ENTERPRISE_ENGINE",
    "modules": ["ACTIVE_SHIELD", "AUDITOR_SUITE", "SAARE_GOVERN"],
    "issued_at": "2026-02-01T00:00:00Z",
    "expires_at": "2027-02-01T00:00:00Z"
  },
  "signature": "u8F3xK...[Firma criptográfica Ed25519 Base64]..."
}
```

8. Matriz de Alineamiento Regulatorio

REGULACIÓN	ARTÍCULO / CONTROL	IMPLEMENTACIÓN TÉCNICA S.A.A.R.E. V4	ESTADO
EU AI Act	Art. 10: Gobernanza de Datos[cite: 2].	Interceptación de prompts y análisis de sesgos ex-ante en Capa 7[cite: 2].	100% CUMPLIDO[cite: 2]
EU AI Act	Art. 12: Trazabilidad y Logging[cite: 2].	Generación síncrona de sellos HMAC-SHA256 e integración SIEM/SOAR[cite: 2].	100% CUMPLIDO[cite: 2]
ISO/IEC 42001	A.2.1: Políticas de IA[cite: 2].	Motor de reglas con ejecución determinista de políticas corporativas[cite: 2].	100% CUMPLIDO[cite: 2]
ISO/IEC 42001	A.8.1: Impacto y Privacidad[cite: 2].	Anonimización de PII/PHI en RAM previo a la transmisión fuera del perímetro[cite: 2].	100% CUMPLIDO[cite: 2]
RGPD	Art. 32: Seguridad y Cifrado[cite: 2].	Procesamiento Zero-Disk en memoria volátil y purga física vía madvise[cite: 2].	100% CUMPLIDO[cite: 2]
DORA	Art. 6: Riesgos de TIC[cite: 2].	Arquitectura resiliente con degradación elegante y latencia < 1.2 ms[cite: 2].	100% CUMPLIDO[cite: 2]

9. Benchmark SLA y Dictamen Final

NODO	CANAL IPC / INTERFAZ	MUESTRA EVALUADA	RECHAZOS	LATENCIA PROMEDIO
Nodo-Alfa	Pasarela Local (`/var/run/saare_core.sock`) [cite: 2]	6,413 reqs[cite: 2]	140 reqs[cite: 2]	1.150 ms[cite: 2]
Nodo-Beta	Local IPC Copy[cite: 2]	4,105 reqs[cite: 2]	91 reqs[cite: 2]	1.156 ms[cite: 2]
Nodo-Gamma	Unix Domain Socket[cite: 2]	2,671 reqs[cite: 2]	138 reqs[cite: 2]	1.127 ms[cite: 2]
Nodo-Delta	POSIX Shared Memory[cite: 2]	981 reqs[cite: 2]	5 reqs[cite: 2]	1.154 ms[cite: 2]

DICTAMEN FINAL DE CERTIFICACIÓN DE INFRAESTRUCTURA

El sistema S.A.A.R.E. v7.0 PRO bajo el Framework V4 acredita una latencia media global de **1.147 ms**, cumpliendo el SLA exigido para despliegues de alta frecuencia sin introducir cuellos de botella[cite: 2].